

IDS/IPS & Firewall Evasion

Why evasion matters + ethics

Evasion studies teach you what detectors see – so you can build detections that survive real attacks. The lab target is *your own* IDS (Snort/Suricata deployed on your Kali or a VM), never a third party.

nmap evasion palette

```
nmap -f -D RND:10 -sS target      # fragment + decoy
nmap --ttl 128 -sS target        # weird TTL
nmap --spoof-mac <mac> target
nmap -T1 --scan-delay 500ms target # slow, low noise
nmap -g 53 target                # source port 53 (DNS) to dodge FW rules
nmap -sS --data-length 8 -Pn target
```

Detection-tech basics you must know

Detector	Sees	Evader beats with
Signature IDS	Known byte patterns	Polymorphism, encoding, fragments
Anomaly IDS	Deviations from baseline	Blend into baseline (slow, realistic)
Protocol analysis	Malformed/suspicious behavior	Use valid protocol semantics

Fragment & trick details

- Fragmentation: IP fragments split the intent (signature doesn't reassemble) – old-school, modern IDS reassembles
- Session splicing / Unicode on HTTP – case, encoding confusion

Encrypted payloads (HTTPS/SSH) – IDS sees ciphertext (this is why TLS-visible DPI needs VPN/proxy layers)

Mimicry: use legitimate tools in legit ways (PowerShell, normal HTTP), the highest-evasion path is 'borrowed traffic'

The defender's counter

Suricata/Snort + Zeek: reassembly off, protocol parsers, sessions

Behavioral + correlation, not just signatures

Log everything (even 'noisy' = find anomalies later)

Deploy Honeypots: attackers who evade the IDS still feed the honeypot

The way to defeat evasion is layered:
signature+protocol+behavior+context. Evasion wins against single-layer detection; loses against the stack.

[← Botnets & Amplification Atta...](#)

[Honeypots & Deception →](#)